

Securing the SSH Service

The SSH service is very widely used in open source infrastructure set-ups. Though SSH stands for Secure Shell, it is found to be highly vulnerable to security attacks if sufficient care is not taken by systems administrators during the installation and configuration. Read on to learn more about such challenges and solutions.

Due to its small footprint on the network, as well as the ease of installation and maintenance, SSH replaces many remote shells in modern data centres. Before we talk about securing SSH, it is imperative to understand how the protocol works, and the bells and whistles provided for security configurations.

How SSH works

Please refer to Figure 1, which shows the protocol stack that forms the SSH services. The Secure Shell (SSH) protocol runs as a daemon service on Linux servers, similar to Telnet, while the client uses an SSH client utility such as Putty to connect to the server. SSH is available on Windows as well as UNIX platforms, and is widely used in Linux infrastructures. By default, it uses TCP port 22 for communication. Unlike Telnet, SSH uses cryptography for authenticating the client and the server, and also for data transfer purposes, thus ensuring data confidentiality and data integrity. Its communication has three basic steps—the client-server handshake, authentication and secure data exchange. During the handshake phase, both the sides exchange information about the SSH protocol version and the cipher algorithms they support (which are typically the combinations of

asymmetric and symmetric encryption, as well as hashing algorithms) and compression algorithms. Unlike SSL, in SSH the server sends the first data block to the client.

As for authentication, the server is authenticated using a host key, while the client typically stores the key fingerprint at some predefined location and validates it later in the process. Please see Table 1, which shows the supported client authentication methods.

Table 1

Client authentication method	Description
Public authentication	Client and server have key pairs and exchange public keys during the authentication process
Password authentication	Plain text password for the given login user is used for authentication
Host-based authentication	Limits client access to a particular host/hosts
Keyboard authentication	Works on the basis of pre-stored security questions and answers

As for the SSH configuration, it is important to remember the files and their paths (Table 2).

